ONE-PAGE BRIEF

Post-quantum cryptography review: sapling-crypto @ 88a7946b4a30

Client: Electric Coin Company (Zcash) — public repository (passive review) · Source: github.com/zcash/sapling-crypto, commit `88a7946b4a30` · Reviewed: 2026-11-04 20:11 UTC · Risk profile: Crypto exchange, custodian or wallet

POST-QUANTUM MATURITY
Level 0 of 4
no post-quantum cryptography

FINDINGS
0 Critical **0** High **5** Medium
2 Low **3** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)
Signatures: 10 + 5 − 8 = 7 → **too late**

Next step: Inventory where classical public-key cryptography protects long-lived data and keys, and choose the first migration: usually a hybrid TLS key exchange and wrapped keys.

WHAT MATTERS MOST

Medium QSI-2026-13306	**Quantum-vulnerable Pedersen commitment: threshold signing and MPC protocols (19 file(s))** preliminary What to do: Track post-quantum threshold signatures (NIST IR 8214C) and keep the protocol layer ready to swap the signature scheme; record which keys...
Medium QSI-2026-13309	**Quantum-vulnerable BLS12-381: threshold signing and MPC protocols (1 file(s))** preliminary What to do: Track post-quantum threshold signatures (NIST IR 8214C) and keep the protocol layer ready to swap the signature scheme; record which keys...
Medium QSI-2026-13310	**Quantum-vulnerable RedDSA: transaction and message signing (1 file(s))** preliminary What to do: Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum signature schemes as chains...
Medium QSI-2026-13307	**Quantum-vulnerable RedDSA: role not determined (2 file(s))** preliminary What to do: Classify each usage, record data lifetimes, and plan migration to a post-quantum algorithm; introduce an abstraction layer for...

3 more in the full report.

WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

Role	Algorithms	What to do
Medium threshold signing and MPC protocols	Pedersen commitment, BLS12-381	Track post-quantum threshold signatures (NIST IR 8214C) and keep the protocol layer ready to swap the...
Medium transaction and message signing	RedDSA	Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum...
Medium role not determined	BLS12-381, RedDSA	Classify each usage, record data lifetimes, and plan migration to a post-quantum algorithm; introduce an...

KNOWN VULNERABLE COMPONENTS

Advisories for the versions in use: 2; each needs checking against the code.

Static review of source code and manifests; files analysed: 37. No requests were sent to the owner's systems.

Full report, content SHA-256: `9d29799e58681f3f486cdb85bb8a40693447a9b1f3c3a71afd7ed34e1c656f82`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.